PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Déploiement du protocole 802.1X

03-380 ANSSI - Recommandations de déploiement du protocole 802.1X — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le choix du protocole AAA doit privilégier RADIUS car Diameter est rarement implémenté dans les clients courants.
2. Pour une sécurité optimale, il faut utiliser des protocoles avec couche cryptographique standard et authentification mutuelle comme EAP-TLS.
3. La disponibilité du réseau dépend de la disponibilité du serveur car un port de connexion reste fermé par défaut en l'absence de réponse.

Architecture et protocoles 802.1X

Notion	À retenir
Composants et connexion	Les **clients** (commutateur, borne) offrent des **ports** aux **supplicants**, état piloté par le **serveur**. Étapes : **initialisation**, **identification**, **négociation EAP**, **authentification**. Résultat : `Access-Accept` (autorisé) ou `Access-Reject` (non autorisé).
Choix protocole AAA	La norme cite **RADIUS** et **Diameter**. **RADIUS** est recommandé car **Diameter** est rarement implémenté dans les clients courants.
Protocoles EAP	**EAP-MD5** : faible (pas d'authentification serveur). **EAP-MSCHAPv2** : mutuel mais faible (clé **DES**). **EAP-TLS** : mutuel par **certificats** (sûr). **EAP-PEAP** : tunnel **TLS** + méthode interne. **EAP-TTLSv0** : tunnel **TLS** (certificat serveur uniquement).

Recommandations d'authentification et d'autorisation

Notion	À retenir
Authentification/Autorisation	Authentifier est insuffisant : utiliser une **liste exhaustive d'identités autorisées**. Assurer la **cohérence de l'identité** et protéger la **confidentialité/intégrité** des éléments secrets.
Protocoles et encapsulation	Utiliser des protocoles avec **couche cryptographique standard** et **authentification mutuelle** (**EAP-TLS**, **EAP-TTLS**, dernières versions de **PEAP**). Interdire explicitement les méthodes **non encapsulées** (**EAP-MSCHAPv2**, **EAP-MD5** seuls).
Réseau sans fil	Déployer **WPA2-Enterprise** avec **TLS récent** et suite assurant la **confidentialité persistante**. **PEAP/EAP-MSCHAPv2** respecte la génération de clés via éléments négociés, contrairement à **EAP-TTLS** (homme du milieu possible).

Sécurisation du réseau de confiance

Notion	À retenir
Protection et redondance	Machine **physique dédiée** ou **virtualisée** (services identiques), configuration **durcie**, et au moins **2 serveurs** pour la disponibilité.
Cloisonnement et intégrité	Réseau **dédié distinct**, secrets **distincts par client** (**22 caractères ASCII**, entropie **128 bits**), utiliser **RadSec**, **DTLS** ou **IPsec**.
Journalisation	Fonction de journalisation des événements **mise en œuvre et supervisée** ; le fonctionnement nominal ne génère normalement **pas de messages d'erreur**.

VLAN et limites du 802.1X

Notion	À retenir
L'affectation de VLAN	Priorité à l'**affectation statique**. L'**affectation dynamique** est possible si les clients filtrent les VLAN et que les **VLAN d'administration** ne sont **jamais** affectés dynamiquement (numéro en clair dans le paquet `RADIUS`).
Les limites intrinsèques	Un concentrateur ou un matériel de faible coût peut détourner l'accès. Solution : **limiter à une seule adresse MAC**, utiliser **MACsec**, cloisonner, superviser et restreindre les services en **authentification automatique**.

Décision de déploiement du 802.1X

Notion	À retenir
Scénarios recommandés	Tout **réseau sans fil** ; réseau filaire à **sécurité physique non garantie** (ex: **salles de réunion**) ; prises en **accès libre** avec **affectation dynamique de VLAN**.
Scénarios non indispensables	Accès au réseau **inaccessible** pour un individu malveillant et **câblage maîtrisé**. Nécessite toutefois la **limitation du nombre d'adresses MAC** par port.

Pièges et confusions

- ⚠ Confondre la protection d'un mot de passe avec celle d'une clé privée (la première ne peut être garantie par des moyens purement techniques).
- ⚠ Croire que l'activation globale de l'affectation dynamique de VLAN est sans risque pour le serveur RADIUS.
- ⚠ Penser que le 802.1X seul permet de contrer un équipement spécifique intercalé entre un client et un supplicant sans MACsec.
- ⚠ Considérer que l'authentification seule suffit sans utiliser une liste exhaustive d'identités autorisées.

Sigles et définitions

802.1X	réseau dont l'accès est protégé par des mécanismes AAA, authentification, autorisation et traçabilité
authenticator	client, élément de confiance servant de point d'accès au réseau, comme un commutateur ou un point d'accès Wi-Fi
supplicant	logiciel sur l'équipement d'extrémité qui cherche à se connecter au réseau à accès contrôlé
EAP	Extensible Authentication Protocol, protocole abstrayant le mécanisme d'authentification
EAPoL	Extensible Authentication Protocol over LAN, encapsulation d'EAP sur les réseaux locaux
réseau de confiance	réseau maîtrisé transportant les échanges entre le serveur et les clients, considéré comme sûr
WPA2-Enterprise	réseau sans fil où chaque supplicant dispose de sa propre clé de protection négociée durant l'authentification
MACsec	fonctionnalité sécurisant par des moyens cryptographiques la connexion filaire entre supplicant et client

Auto-test

1. Quel est le résultat d'une authentification réussie ?
2. Quelle méthode EAP est jugée faible car elle ne propose pas d'authentification serveur ?
3. Combien de serveurs minimum faut-il pour assurer la disponibilité ?
4. Quelle est la longueur recommandée pour les secrets par client ?
5. Quel protocole est recommandé pour le réseau sans fil avec TLS récent ?

Réponses : **1.** Access-Accept · **2.** EAP-MD5 · **3.** au moins 2 · **4.** 22 caractères ASCII · **5.** WPA2-Enterprise

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.